Active Email Threat Investigation Report

By

Oluwatobi Babalola

Phishing Analysis & Incident Response

1. Executive Summary

On July 29, 2023, the Security Operations team was alerted to five suspicious emails reported by users, which were aimed at staff members across various departments. An investigation revealed that four out of the five emails were indeed malicious, indicating a coordinated effort involving phishing and malware distribution. The remaining email was deemed unsolicited commercial spam, lacking any harmful content.

Two of the emails were linked to the same threat actor (alfredegov@gmail.com), suggesting a targeted, multi-faceted attack against the organization. The most critical incident involved confirmed malware delivery systems that were actively distributing executable payloads on the day of the attack, with the payload server identified as part of an active command-and-control (C2) network.

It is strongly advised to take immediate containment measures for the accounts and devices associated with Michelle Jackson, Nike Fury, and Lily Tunechy. Additionally, display name spoofing aimed at Shina Kagawa has been traced back to the same actor responsible for the Adobe impersonation incident..

Email / Recipient	Sender	Classification	Severity	Action
Affiliate Marketing(Kendrick Lawal)	jasonconrad099@gmail.com	Spam / Unsolicited	**LOW**	Monitor / Filter
Code Review Request(Michelle Jackson)	zelatcol@gmail.com	Malware Delivery (NjRAT)	**HIGH**	Isolate / Investigate
Project Files Download(Nike Fury)	projectdept@kanzalshamsprojectmgt.com	Phishing / Malware Delivery	**HIGH**	Isolate / Investigate
Adobe Update(Lily Tunechy)	alfredegov@gmail.com	Brand Impersonation + Malware	**CRITICAL**	Isolate / Escalate
Team Building Activity(Shina Kagawa)	alfredegov@gmail.com(spoofing Kendrick Lawal)	Display Name Spoof + Browser Attack	**MEDIUM-HIGH**	Block / Notify

2. Investigation Steps

The following methodology was applied consistently across all five emails:

Step 1 — Email header analysis: Examined From, Return-Path, Received chain, Authentication-Results (SPF/DKIM/DMARC), and Microsoft SCL score to identify anomalies.
Step 2 — Sender verification: Cross-referenced sender addresses against known staff directories and prior correspondence to identify spoofing or impersonation.
Step 3 — URL and domain analysis: Submitted all links and domains to VirusTotal and URLScan.io for reputation checks, redirect chain analysis, and behavioural scanning.
Step 4 — Payload analysis: Where executable or download links were identified, submitted to VirusTotal for hash-based malware family identification and C2 infrastructure mapping.
Step 5 — Correlation: Cross-referenced sender addresses, infrastructure, and IOCs across all five emails to identify campaign linkages.
Step 6 — Verdict and response: Assigned severity rating and determined appropriate containment and eradication actions per email.

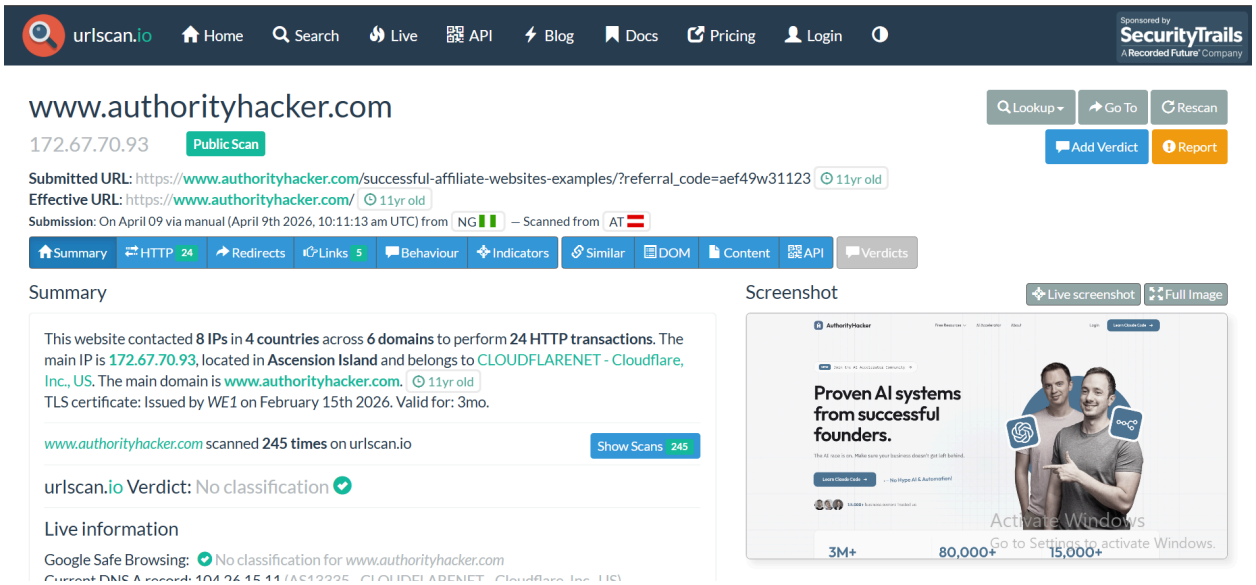
3. Findings & Evidence

3.1 Email 1 — Affiliate Marketing Best Practices (Kendrick Lawal)

Field	Detail
Sender	Jason Conrad <jasonconrad099@gmail.com>
Recipient	kendrick.lawal@company.com
Auth (SPF/DKIM/DMARC)	All pass (gmail.com) — legitimate Gmail account, not spoofed
SCL Score	1 — Not flagged as spam by Microsoft Exchange
Link	https://www.authorityhacker.com/successful-affiliate-websites-examples/?referral_code=aef49w31123
Verdict	SPAM — Unsolicited Commercial Email. Not malicious.

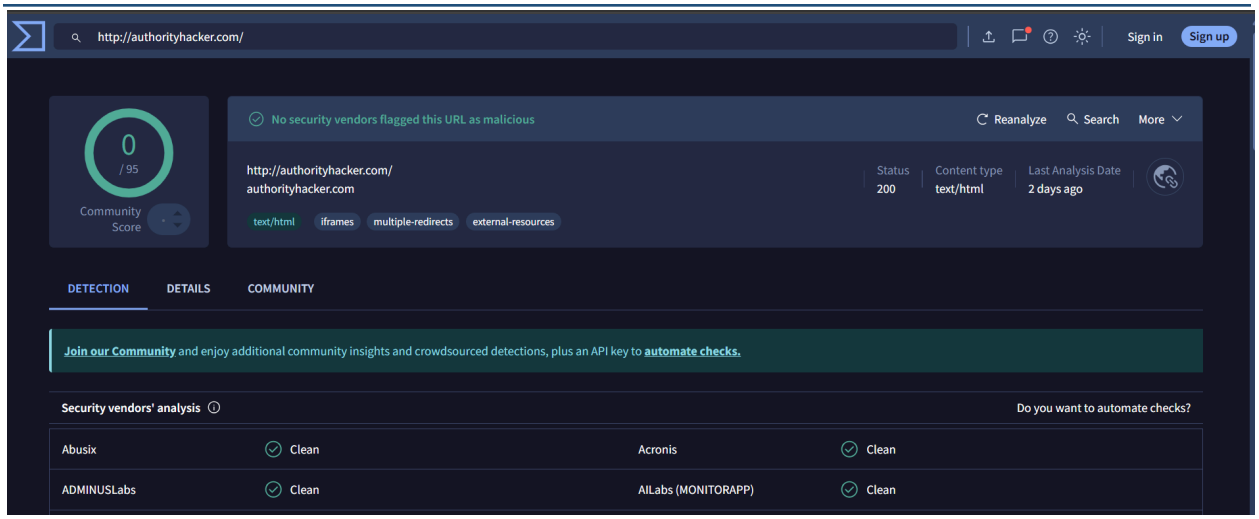
Evidence

URLScan.io confirmed the submitted URL redirected via HTTP 301 to the root domain www.authorityhacker.com. No redirect to malicious infrastructure was detected. The domain is 11 years old and hosted on Cloudflare. The referral code parameter (aef49w31123) is a standard affiliate tracking parameter used by the authorityhacker.com platform.



URLscan.io - authorityhacker.com summary showing 11yr old domain, HTTP 301 redirect, No classification verdict

VirusTotal returned 0/95 detections for authorityhacker.com. No security vendor flagged the domain as malicious.



authorityhacker.com showing 0/95 detections, all vendors Clean

Response Actions

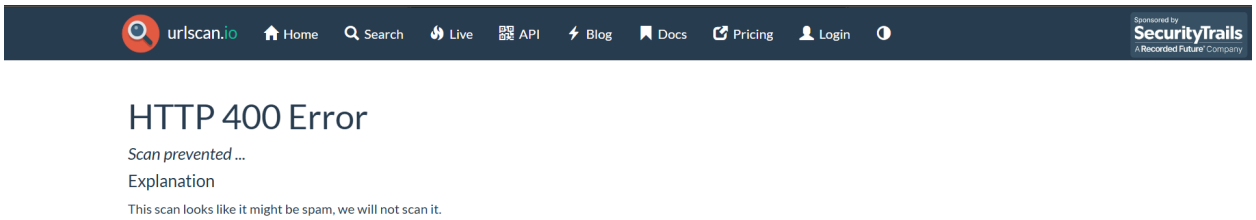
- No containment required — link destination confirmed safe.
- Advise Kendrick Lawal that the link is not malicious but the email is unsolicited spam from an unknown external sender.
- Consider creating a mail filter rule to block future emails containing affiliate referral links from unrecognised external senders.

3.2 Email 2 — Code Review Request (Michelle Jackson)

Field	Detail
Sender	Darren Zelat <zelatcol@gmail.com>
Recipient	michelle.jackson@company.com
Auth (SPF/DKIM/DMARC)	All pass (gmail.com)
SCL Score	1 — Not flagged by Exchange
Link	https://wtools.io/paste-code/bOs4
Verdict	MALICIOUS — NjRAT Remote Access Trojan delivery. HIGH severity.

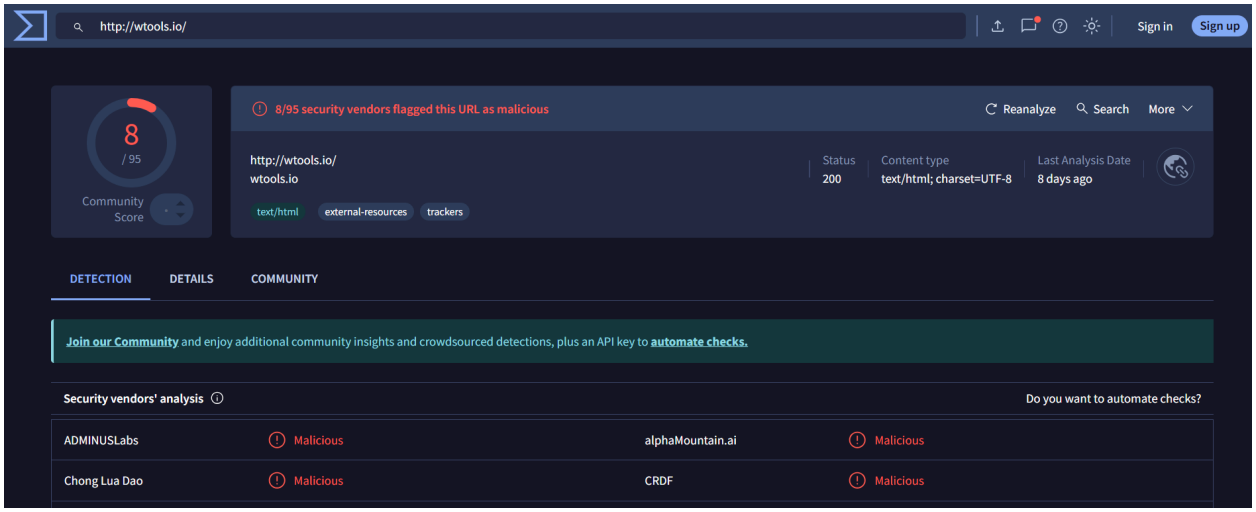
Evidence

URLScan.io refused to scan the URL, returning HTTP 400 with the message 'This scan looks like it might be spam, we will not scan it.' This constitutes an additional indicator of suspicious activity.



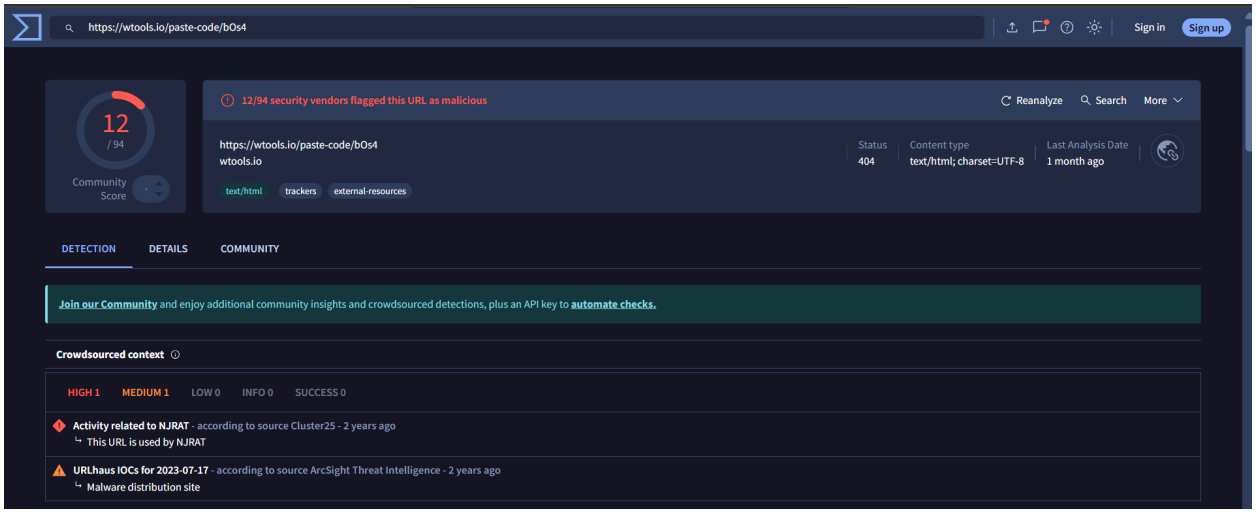
HTTP 400 error, scan refused for wtools.io/paste-code/bOs4

VirusTotal returned 8/95 detections for the wtools.io domain, flagged as malicious by ADMINUSLabs, alphaMountain.ai, Chong Lua Dao, and CRDF among others.



VirusTotal — wtools.io domain showing 8/95 malicious detections

VirusTotal returned 12/94 detections for the specific URL https://wtools.io/paste-code/bOs4. The Crowdsourced Context section confirms HIGH severity NjRAT activity attributed by Cluster25, and a MEDIUM severity URLhaus IOC entry dated 2023-07-17 classifying the URL as a malware distribution site. The URL returns a 404 status, indicating the paste has since been removed.



VirusTotal — wtools.io/paste-code/bOs4 showing 12/94 detections, NjRAT HIGH severity tag from Cluster25, URLhaus IOC MEDIUM tag

NjRAT — Threat Context

NjRAT, which is also referred to as Bladabindi, is a thoroughly documented Remote Access Trojan. Its capabilities encompass: complete remote control of the victim's machine, keylogging, access to the webcam and microphone, harvesting credentials from browsers, reading, writing, and deleting files in the system, as well as installing a persistent backdoor. As the Lead Software Engineer, Michelle Jackson probably has access to source code repositories, internal systems, and possibly production credentials, rendering her a high-value target.

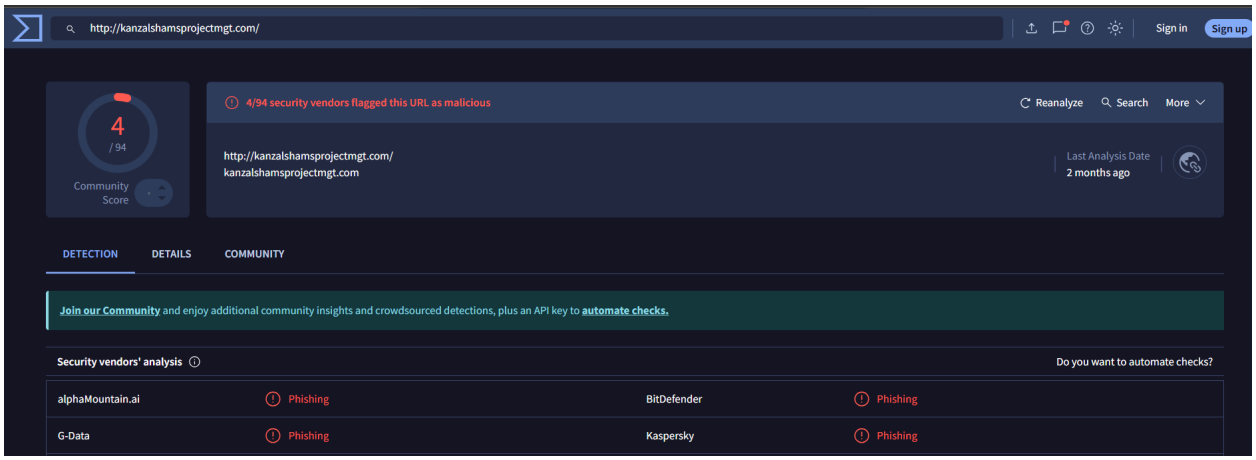
Response Actions

- Promptly examine the proxy and firewall logs for any outbound connections to wtools.io originating from Michelle Jackson's machine on or after July 29, 2023.
- If a connection is verified: disconnect the device from the network, start forensic imaging, and reset all credentials linked to Michelle's accounts.
- Inspect audit logs for any unusual activity from michelle.jackson@company.com following the email.
- Restrict access to wtools.io at both the email gateway and web proxy.

3.3 Email 3 — Download Updated Project Files (Nike Fury)

Field	Detail
Sender	Project Management Office <projectdept@kanzalshamsprojectmgt.com>
Recipient	nikefury@company.com
Header Anomaly	DKIM signed by gmail.com, not kanzalshamsprojectmgt.com — From address spoofed via Gmail infrastructure
SCL Score	1 — Not flagged by Exchange
Link	https://drive.google.com/uc?export=download&id=1bstuGMLer-fbJbcGG5JiqnleKTSKvq5y
Verdict	MALICIOUS — Phishing with malware delivery via Google Drive. HIGH severity.

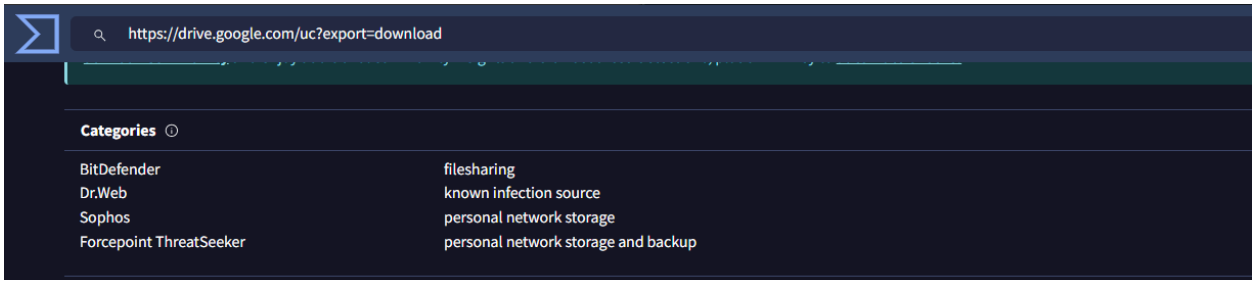
Evidence
VirusTotal returned 4/94 detections for kanzalshamsprojectmgt.com. All four detections, alphaMountain.ai, BitDefender, G-Data, and Kaspersky, categorised the domain as Phishing, confirming this is not a legitimate organisation.



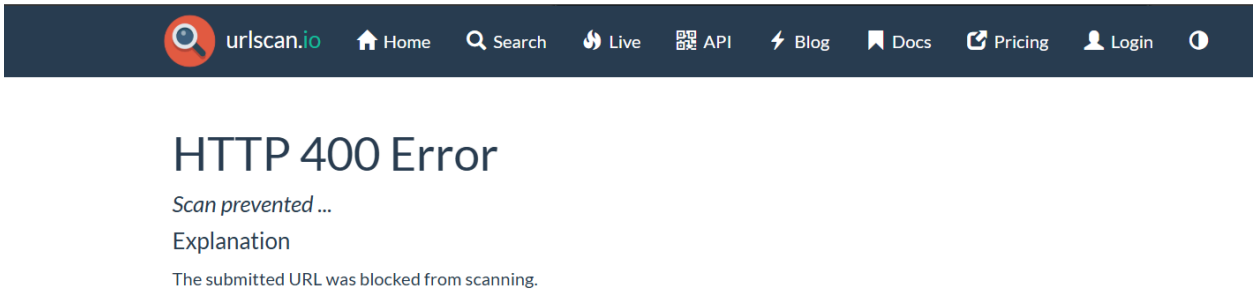
VirusTotal — kanzalshamsprojectmgt.com showing 4/94 detections, all categorised as Phishing

VirusTotal returned 1/95 detections for the Google Drive download URL. Dr.Web categorised the drive.google.com/uc?export=download endpoint as a 'known infection source'. URLScan blocked the URL from scanning, consistent with its known use as a malware delivery vector. The file behind the download ID is no

longer accessible (HTTP 400/404), indicating it was removed post-delivery.



VirusTotal — Google Drive download URL showing 1/95 detection, Dr.Web 'known infection source' category



URLScan.io — HTTP 400 error, Google Drive URL blocked from scanning

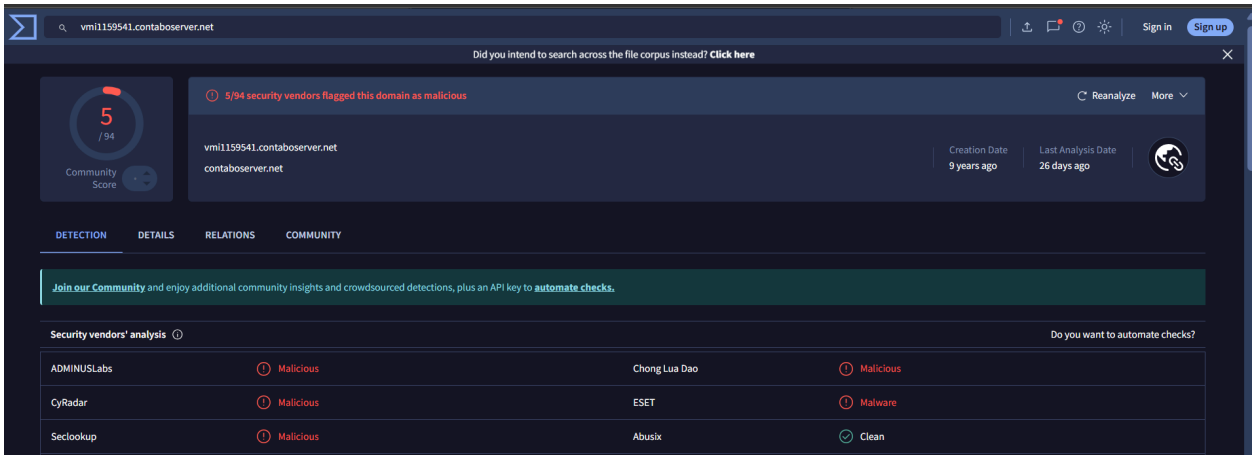
Response Actions

- Check proxy and firewall logs for outbound connection to the Google Drive download URL from Nike Fury's machine on or after 29 July 2023.
- If download is confirmed: isolate device, initiate credential reset for all systems Nike has access to.
- Block kanzalshamsprojectmgt.com at the email gateway.
- Investigate whether other staff received emails from the same sender domain.

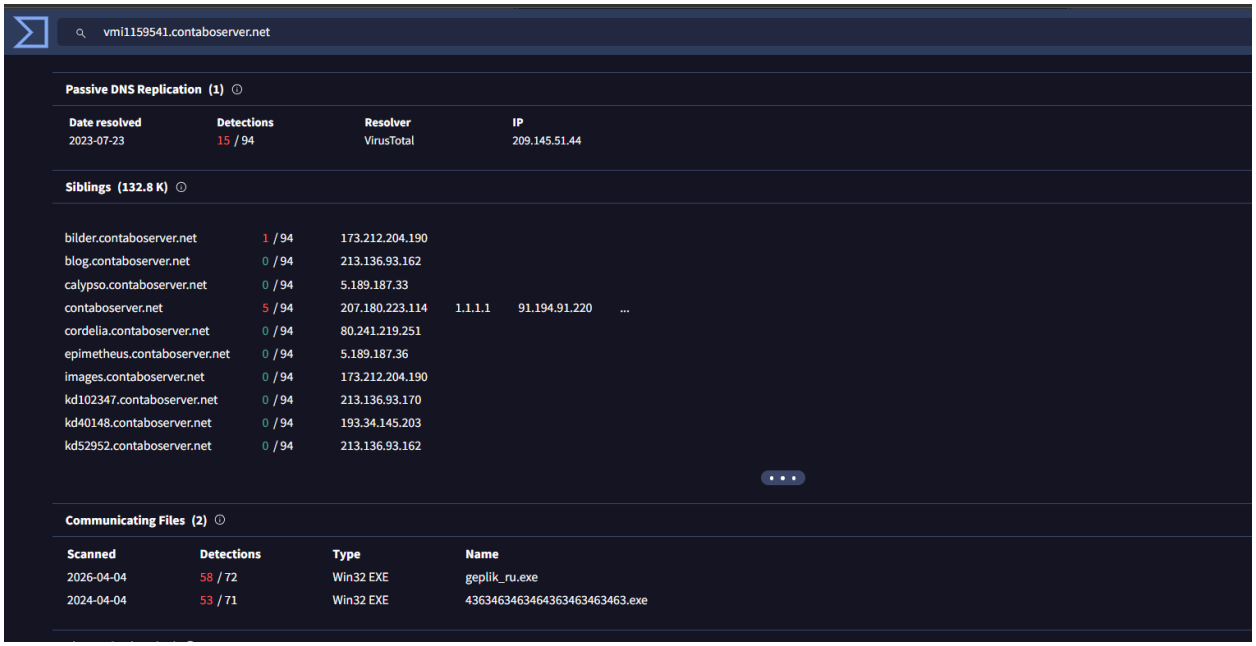
3.4 Email 4 — Important Adobe Update (Lily Tunechy)

Field	Detail
Sender	Jason Conrad <alfredegov@gmail.com>
Recipient	lily.tunechy@company.com
Auth (SPF/DKIM/DMARC)	All pass (gmail.com)
SCL Score	5 — Flagged as Junk by Microsoft Exchange. Delivered to the Junk folder.
URL Deception	Display text: update.adobe.com/latest-security-updates | Actual href: http://updetadobe.blogspot.com/atom.xml
Payload URL	http://vmi1159541.contaboserver.net/payload.exe (present in plain text version)
Verdict	MALICIOUS — Brand impersonation (Adobe) + direct malware delivery via Contabo C2. CRITICAL severity.

Evidence
VirusTotal returned 5/94 detections for vmi1159541.contaboserver.net. ESET specifically categorises this as Malware. The Details tab confirms the server IP as 209.145.51.44. The Relations tab reveals 130+ communicating malware files including geplik_ru.exe (58/72 detections) and 436346346346343634634 63.exe (53/71 detections), confirming this is active C2 infrastructure. Passive DNS records show 15/94 detections when this IP was resolved on 2023-07-23, six days before the email was sent.

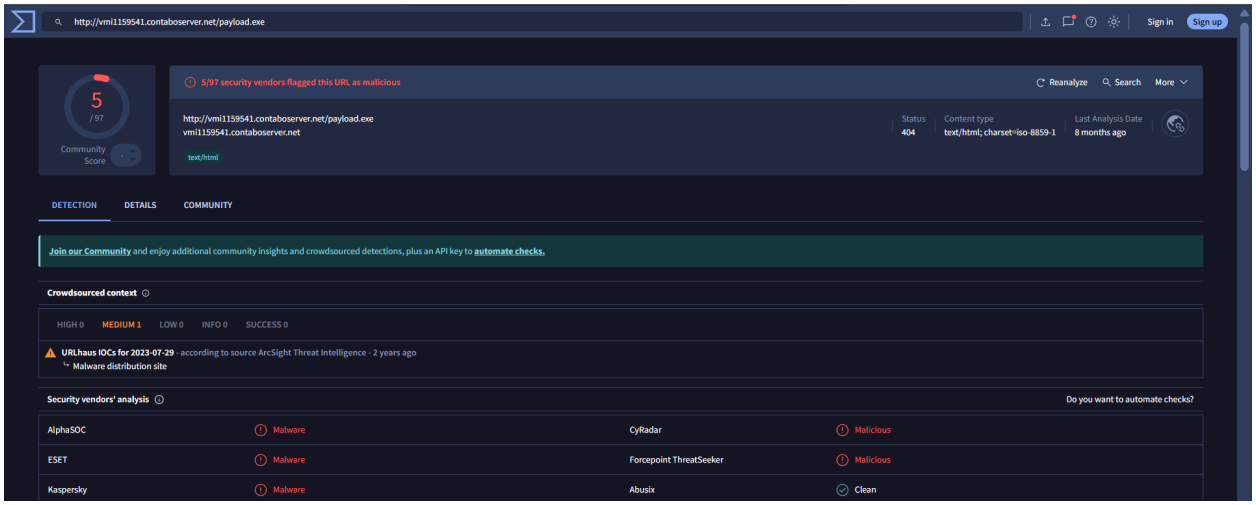


VirusTotal — vmi1159541.contaboserver.net Detection tab showing 5/94, ESET Malware detection



VirusTotal — vmi1159541.contaboserver.net Relations tab showing Communicating Files: geplik_ru.exe (58/72) and 436346346346346346463.exe (53/71)

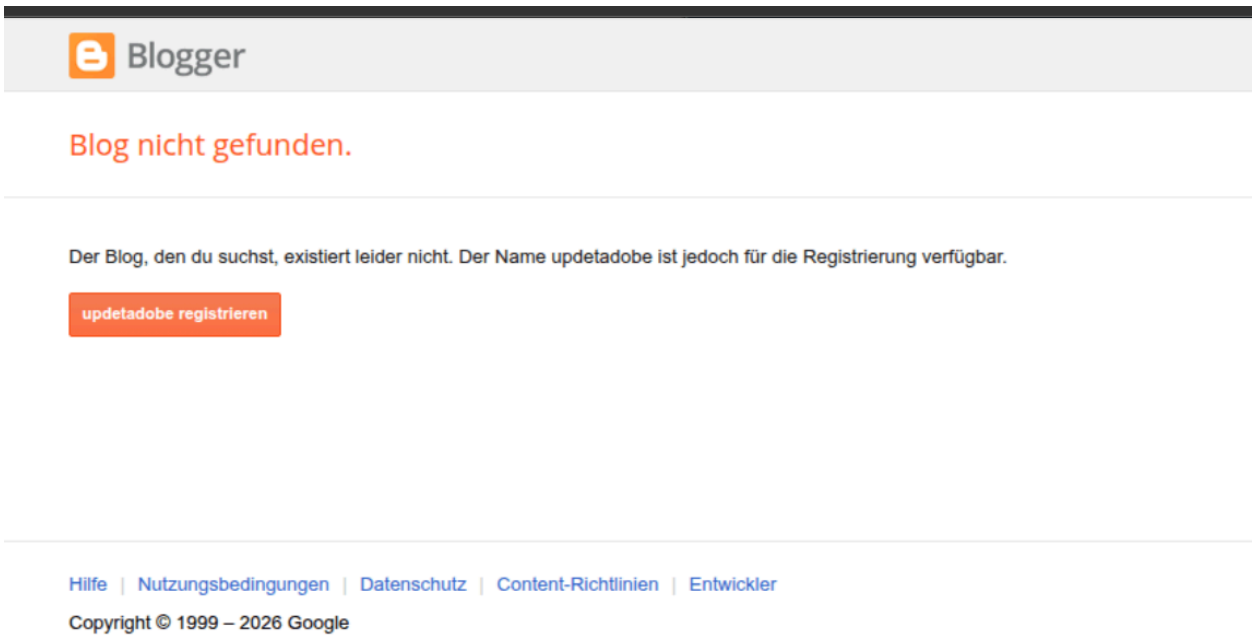
VirusTotal returned 5/97 detections for the payload URL http://vmi1159541.contaboserver.net/payload.exe. Vendors flagging as Malware include AlphaSOC, ESET, Kaspersky, and Forcepoint ThreatSeeker (category: 'malicious web sites'). URLhaus Crowdsourced Context confirms this URL was an active malware distribution site on 2023-07-29, the exact date the email was sent.



VirusTotal — payload.exe URL showing 5/97 detections, URLhaus IOC for 2023-07-29, Forcepoint 'malicious web sites' category

VirusTotal returned 6/94 detections for updetadobe.blogspot.com. Kaspersky, Fortinet, and Sophos all categorise this domain as Malware. The domain has been taken down (confirmed via URLScan screenshot showing Blogger 'Blog nicht gefunden' page), but was active at time of the attack.

VirusTotal — updetadobe.blogspot.com showing 6/94 detections, alphaMountain/Bitdefender/Sophos Malware categories



URLScan.io — updetadobe.blogspot.com screenshot showing 'Blog nicht gefunden' — blog taken down

Threat Actor Note

The sender address alfredegov@gmail.com is the same address used in Email 5 (Team Building Activity targeting Shina Kagawa). This confirms a single threat actor conducted a coordinated multi-target campaign on 29 July 2023.

Response Actions

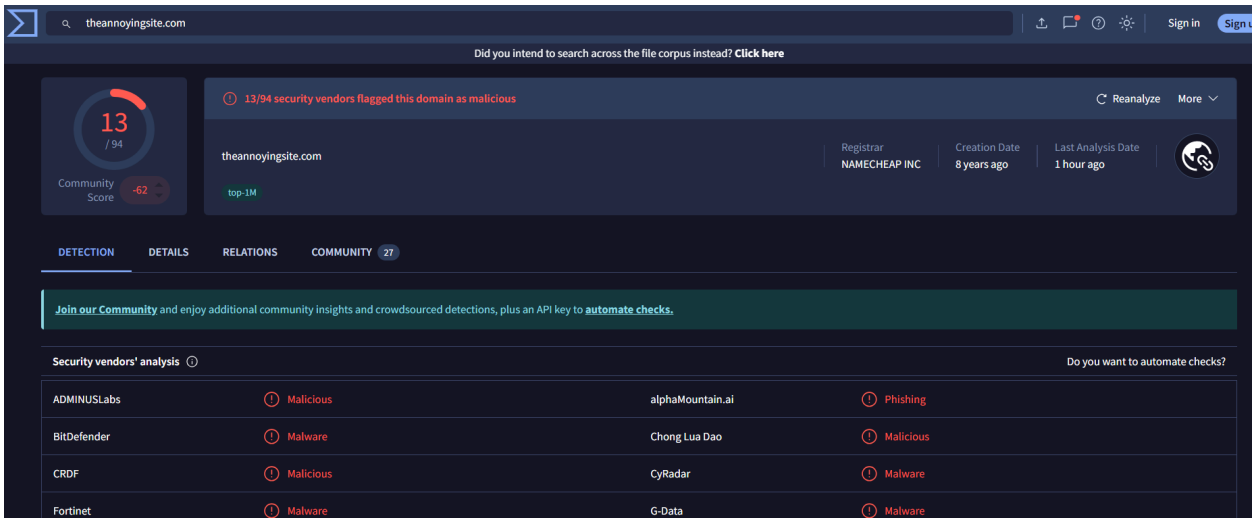
- IMMEDIATE: Check proxy/firewall logs for outbound connections to vmi1159541.contaboserver.net or updetadobe.blogspot.com from Lily Tunechy's machine.
- If connection confirmed: isolate device immediately, initiate full forensic process.
- Block vmi1159541.contaboserver.net (IP: 209.145.51.44) and updetadobe.blogspot.com at firewall and email gateway.
- Add alfredegov@gmail.com to the email blocklist.
- Escalate to CISO, active C2 infrastructure with confirmed communicating malware files.

3.5 Email 5 — Team Building Activity (Shina Kagawa)

Field	Detail
Sender	alfredegov@gmail.com (display name: Kendrick Lawal — SPOOFED)
Recipient	shina.kagawa@company.com
Spoofing Type	Display name spoofing — impersonating internal colleague Kendrick Lawal (Head of Marketing)
SCL Score	1 — Not flagged by Exchange
Link	http://theannoyingsite.com
Verdict	MALICIOUS — Display name spoofing + browser-based attack toolkit. MEDIUM-HIGH severity.

Evidence

VirusTotal returned 13/94 detections for theannoyingsite.com, the highest domain detection count of all five emails. Vendors flagging as Malware include BitDefender, CyRadar, Fortinet, and G-Data. alphaMountain.ai categorises it as Phishing. The community score is -62, indicating strong negative consensus among security analysts. The domain is 8 years old (registered December 2017) and appears in the Cloudflare Radar top 1 million websites, consistent with a long-running browser-based harassment platform.



VirusTotal — theannoyingsite.com showing 13/94 detections, Community score -62, Malware/Phishing categories from multiple vendors

The Relations tab reveals 130 communicating malware files and 197 referring files. Notable files include MultiTool.exe (51/72), TrollVirus (not dangerous).exe (44/72), şifrepıtpı.exe (53/72), and Hrax.exe (37/71). This confirms an established malware ecosystem built around this domain.

theannoyingsite.com

www.theannoyingsite.com	9 / 94	50.116.11.184
theannoyingsite.com	13 / 94	50.116.11.184

Communicating Files (130)

Scanned	Detections	Type	Name
2026-03-03	0 / 62	DOS batch file	PV2GH_VIRUS.txt.bat
2026-03-03	0 / 62	VBA	rise up in despair.bat
2025-12-24	0 / 66	ZIP	sProx.zip
2026-03-14	25 / 62	DOS batch file	x.virus.bat
2025-06-20	0 / 62	DOS batch file	why.bat
2024-03-02	12 / 60	Text	3mad_b8rh.bat
2024-03-02	51 / 72	Win32 EXE	MultiTool.exe
2024-03-03	44 / 72	Win32 EXE	TrollVirus (not dangerous).exe
2024-03-02	53 / 72	Win32 EXE	şifrepıtpı.exe
2025-12-04	0 / 62	DOS batch file	158d71ba1b099619adb18524257cb766d30c21b6a359102fb81f5b0ee111b746

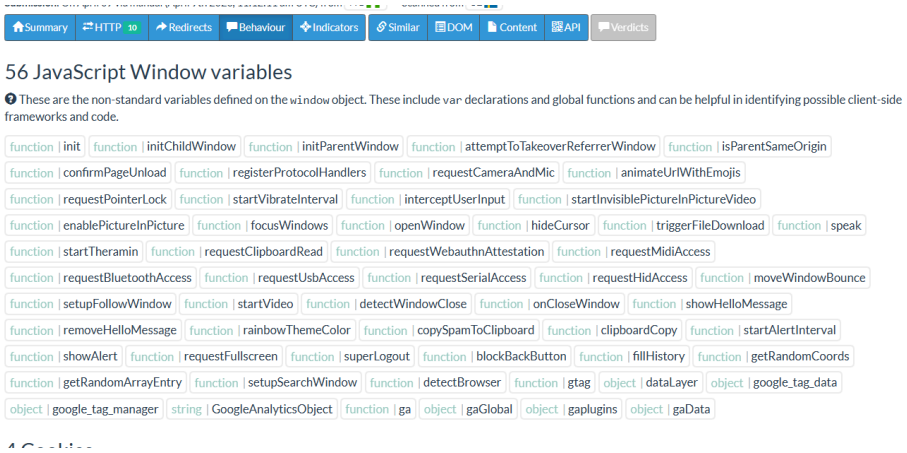
Files Referring (197)

Scanned	Detections	Type	Name
2026-04-08	2 / 61	VBA	Toolbox1.3.0.bat
2026-04-08	2 / 61	VBA	Toolbox1.3.0.bat
2026-04-01	22 / 61	Win32 EXE	Feddy.exe
2026-03-28	6 / 61	VBA	fpsbooster2.vbs
2026-03-27	37 / 71	Win32 EXE	Hrax.exe
2026-03-19	28 / 61	DOS batch file	482e2544ec866fdbc28d043e12001fc0ae50ae947b84e089d33c11b90509bc5c.vba
2026-03-16	26 / 62	DOS batch file	x.virus.cmd
2026-03-14	25 / 62	DOS batch file	x.virus.bat
2026-03-08	25 / 62	DOS batch file	x.virus.cmd
2026-03-08	23 / 62	DOS batch file	x.virus.cmd

VirusTotal — theannoyingsite.com Relations tab showing Communicating Files including MultiTool.exe, TrollVirus.exe with high detection counts

URLScan.io analysis reveals the site renders as an innocuous 'tap the cat' interaction prompt designed to lower user guard. JavaScript analysis identified 56 window functions including: attemptToTakeoverReferrerWindow, requestCameraAndMic, triggerFileDownload, requestClipboardRead, requestWebauthnAttestation, requestBluetoothAccess, blockBackButton, and superLogout, confirming this is a browser-based attack toolkit.

URLScan.io — theannoyingsite.com screenshot showing 'Hi there! Hold down the space key' landing page



URLScan.io — theannoyingsite.com DOM/Behaviour tab showing 56 JavaScript functions including requestCameraAndMic, triggerFileDownload, attemptToTakeoverReferrerWindow

Threat Actor Linkage

The sender's email address alfredegov@gmail.com has been verified as the same one utilized in Email 4 (which involved Adobe impersonation aimed at Lily Tunechy). The act of using a spoofed display name to impersonate Kendrick Lawal, a genuine internal colleague, indicates

that the threat actor possessed prior insight into the organization's staff hierarchy, implying that reconnaissance took place prior to the campaign.

Response Actions

- Block alfredegov@gmail.com at email gateway.
- Advise Shina Kagawa not to interact with the email or visit the link.
- If Shina visited the site: check for any browser permission grants (camera, microphone, clipboard), clear browser data, change passwords as precaution.
- Notify Kendrick Lawal that his name was used in a display name spoofing attack.
- Consider implementing display name spoofing detection rules in the email gateway to flag external emails using internal staff display names.

4. Indicators of Compromise (IOCs)

Type	Value	Source	Threat
Email Address	alfredegov@gmail.com	Header analysis	Threat actor - Emails 4 & 5
Email Address	zelatcol@gmail.com	Header analysis	NjRAT delivery - Email 2
Email Address	jasonconrad099@gmail.com	Header analysis	Spam - Email 1
Domain	wtools.io	VirusTotal	Malware distribution (NjRAT)
URL	https://wtools.io/paste-code/bOs4	VirusTotal / URLhaus	NjRAT payload - Email 2
Domain	kanzalshamsprojectmgt.com	VirusTotal	Phishing domain - Email 3
URL	https://drive.google.com/uc?export=download&id=1bstuGMLer-fbJbcGG5JiqnleKTSKvq5y	VirusTotal	Malware delivery - Email 3
Domain	vmi1159541.contaboserver.net	VirusTotal	Active C2 infrastructure - Email 4
IP Address	209.145.51.44	VirusTotal DNS	Contabo C2 server IP - Email 4
URL	http://vmi1159541.contaboserver.net/payload.exe	VirusTotal / URLhaus	Malware payload - Email 4
Domain	updetadobe.blogspot.com	VirusTotal	Fake Adobe blog - Email 4
Domain	theannoyingsite.com	VirusTotal	Browser attack toolkit - Email 5
IP Address	50.116.11.184	URLScan / VT	theannoyingsite.com hosting IP

5. Consolidated Response Actions

5.1 Immediate Containment

- Isolate devices belonging to Michelle Jackson, Nike Fury, and Lily Tunechy pending log review.
- Check proxy/firewall logs for outbound connections to: wtools.io, kanzalshamsprojectmgt.com, vmi1159541.contaboserver.net (209.145.51.44), updetadobe.blogspot.com, and theannoyingsite.com.
- Reset credentials for any confirmed affected users.

5.2 Eradication

- Block the following at the email gateway: alfredegov@gmail.com, zelatcol@gmail.com, kanzalshamsprojectmgt.com.
- Block the following at the web proxy and firewall: wtools.io, vmi1159541.contaboserver.net, 209.145.51.44, updetadobe.blogspot.com, theannoyingsite.com.
- Create custom Sentinel alerts for all IOCs listed in Section 4.

5.3 Long-Term Recommendations

- Implement display name spoofing detection rules in the email gateway to flag external emails using internal staff names.
- Enable Microsoft Defender for Office 365 Safe Links and Safe Attachments across all mailboxes.
- Conduct phishing awareness training particularly focusing on URL inspection, display name verification, and unsolicited file download requests.
- Review and tighten SCL thresholds, the Adobe email (SCL 5) was delivered to Junk but not blocked. Consider blocking SCL 5+ at gateway level.